

Module 11 Lab:
Penetration Testing in Practice
JR Clark (002035589)
NEU DAMG7350 (Spring 2026)

Table of Contents

<i>Introduction</i>	3
<i>Methodology</i>	3
<i>Findings and Analysis</i>	4
Host and Service Discovery:	4
Analysis of Obsolete and Insecure Services:	4
Web and Application Enumeration:	5
SMB and FTP Misconfigurations:	5
SSH Access and Post-Exploitation:	5
<i>Conclusion</i>	6
References	6
Methodology and Use of AI Tools	6
<i>APPENDIX A: Documented Process</i>	7
<i>APPENDIX B: Risk Summary</i>	16
<i>APPENDIX C: Recommendations</i>	17

Introduction

This lab demonstrates a complete penetration-testing workflow using Kali Linux to assess a vulnerable Metasploitable 2 virtual machine. The objective was to simulate a realistic attacker mindset by performing host discovery, service enumeration, web and SMB/FTP analysis, and authenticated exploitation. The assessment concludes with a post-exploitation persistence technique that demonstrates how an attacker could maintain long-term access to the system. All findings were generated from my own live capture sessions using UTM on macOS, with Kali Linux and Metasploitable configured on the same 192.168.64.0/24 network.

Methodology

The detailed procedural steps, commands, and screenshots for this lab are documented in the Appendix. The methodology below summarizes the structured approach used to complete the assessment.

I began by validating network connectivity between Kali Linux and Metasploitable to ensure that discovery and enumeration tools would function correctly. I then performed active host discovery to identify the target system on the subnet. Once the Metasploitable host was confirmed, I conducted a series of port and service enumeration scans to identify exposed services and potential vulnerabilities.

Following network-level enumeration, I performed web application enumeration to identify accessible directories and configuration disclosures. I then evaluated SMB, FTP, SSH, and RPC services to assess authentication requirements, access controls, and misconfigurations. After confirming that the system allowed SSH access using default credentials, I demonstrated a realistic post-exploitation persistence technique by creating a new user and granting it administrative privileges.

Microsoft Copilot was used as a writing and organizational aid to help structure the report and refine transitions. All technical execution, analysis, and conclusions reflect my own understanding and hands-on work.

Findings and Analysis

Host and Service Discovery

Network discovery confirmed that the Metasploitable host was active on the same subnet and responsive to ICMP traffic. Port and service enumeration revealed a wide range of exposed services, including FTP, SSH, SMTP, DNS, HTTP, SMB, and several legacy remote-access protocols. The breadth of exposed services reflects a highly vulnerable system with minimal hardening.

Analysis of Obsolete and Insecure Services

Two services identified during enumeration were particularly notable due to their age and security implications: Telnet and IRC.

Telnet was exposed on the network and represents a significant security risk. Because Telnet transmits all data in cleartext, including credentials, it is vulnerable to interception and session hijacking. Its presence indicates outdated configuration practices and provides attackers with an immediate opportunity to capture sensitive information or gain unauthorized access.

IRC was also running on the system. While IRC is not inherently malicious, it is rarely used in modern enterprise environments and is commonly associated with botnet command-and-control infrastructure. Its presence on a server suggests unnecessary legacy software that expands the attack surface. An attacker could potentially use IRC as a covert communication channel or as a mechanism for coordinating malicious activity.

These two services are not a comprehensive list of everything outdated or insecure on the system, and a deeper review would undoubtedly uncover additional legacy components. However, Telnet and IRC stood out immediately because they were already considered obsolete and insecure more than twenty-five years ago in both my personal and professional experience. Their continued presence on a modern system highlights how legacy protocols persist long past their safe operational lifespan and underscores the importance of regular service audits and decommissioning of outdated technologies.

Web and Application Enumeration

The HTTP service exposed a default Apache page and an accessible PHP configuration page. The publicly available PHP information page revealed detailed system configuration data, including environment variables and module information. This type of information disclosure assists attackers in tailoring exploits to the system's specific software stack and is considered a significant misconfiguration.

SMB and FTP Misconfigurations

Both SMB and FTP services allowed anonymous access without requiring authentication. SMB null-session access exposed multiple shares, including a world-writable temporary directory. FTP similarly permitted anonymous login and directory browsing. These misconfigurations demonstrate weak access controls and would allow an attacker to upload, modify, or exfiltrate files without credentials.

SSH Access and Post-Exploitation

SSH access was obtained using default credentials, which provided full shell access to the system. Once authenticated, I demonstrated a realistic persistence technique by creating a new user and granting it administrative privileges through modification of the sudoers file. This

confirmed that an attacker could establish long-term, privileged access with minimal effort and without detection unless system administrators manually audited privileged accounts.

Conclusion

This lab demonstrates how a vulnerable system with outdated services, weak authentication, and misconfigured access controls can be systematically enumerated and compromised. Through a combination of network discovery, service enumeration, and exploitation of default credentials, I gained full shell access to Metasploitable. From there, I created a new privileged user and modified the sudoers file to establish persistent administrative access. These findings highlight the importance of disabling legacy services, enforcing strong authentication, and regularly auditing privileged accounts to reduce the risk of compromise.

References

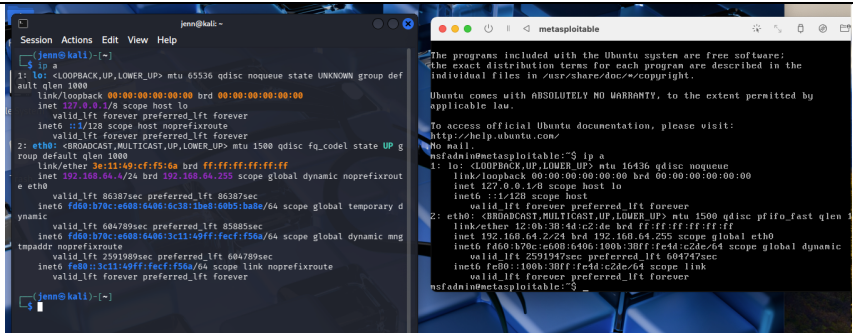
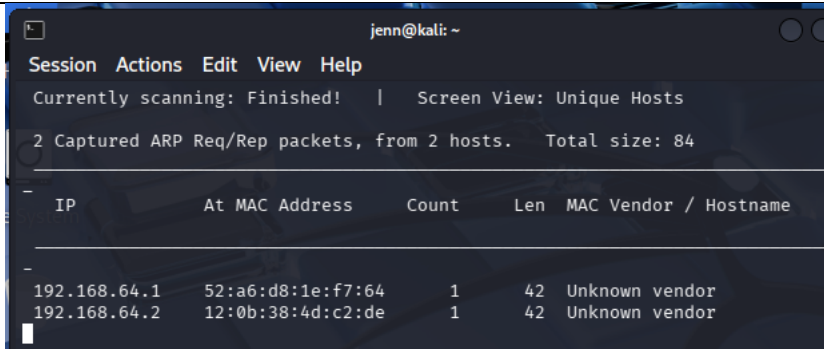
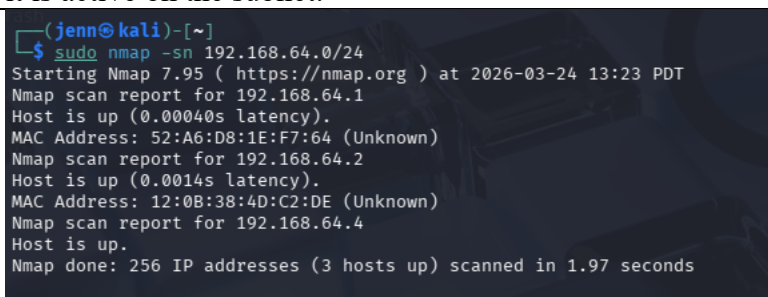
Sawant, A. (2026). Vulnerability Assessment and Penetration Testing [Online course]. Coursera & Northeastern University.

Methodology and Use of AI Tools

I completed all technical steps of this lab directly in the Kali Linux virtual machine. All screenshots and observations were generated from my own live capture sessions. I used Microsoft Copilot as a writing and organizational aid to help structure the report and ensure alignment with the assignment rubric. All analysis, interpretations, and conclusions reflect my own understanding of the material and the concepts covered in Module 11. CoPilot was utilized to validate my understanding of the risks against the CIA Triad for Appendix B.

APPENDIX A: Documented Process

The following table documents the exact steps performed for this lab, with each left-column description corresponding to the screenshot or output shown in the right column.

Step 1: Using UTM on my Mac OS, I setup Kali Linux and Metasploitable – confirm the ip addresses. This screen capture shows they are both on 192.168.64.2/24 Kali MAC: 3E:11:49:CF:F5:6A Metasploitable MAC: 12:0B:38:4D:C2:DE	 Screenshot shows both VMs running in UTM with IPs in the same /24 network. Kali and Metasploitable each display their assigned IP and MAC addresses, confirming they can communicate.															
Step 2: Active discovery - netdiscover	 <table><tr><th>IP</th><th>At MAC Address</th><th>Count</th><th>Len</th><th>MAC Vendor / Hostname</th></tr><tr><td>192.168.64.1</td><td>52:a6:d8:1e:f7:64</td><td>1</td><td>42</td><td>Unknown vendor</td></tr><tr><td>192.168.64.2</td><td>12:0b:38:4d:c2:de</td><td>1</td><td>42</td><td>Unknown vendor</td></tr></table> Terminal output of <code>sudo netdiscover -i eth0 -r 192.168.64.0/24</code>. Metasploitable appears as the second host discovered, confirming it is active on the subnet.	IP	At MAC Address	Count	Len	MAC Vendor / Hostname	192.168.64.1	52:a6:d8:1e:f7:64	1	42	Unknown vendor	192.168.64.2	12:0b:38:4d:c2:de	1	42	Unknown vendor
IP	At MAC Address	Count	Len	MAC Vendor / Hostname												
192.168.64.1	52:a6:d8:1e:f7:64	1	42	Unknown vendor												
192.168.64.2	12:0b:38:4d:c2:de	1	42	Unknown vendor												
Step 3: Active discovery – Ping Sweep	 Output of the ping sweep script showing Metasploitable responding to ICMP echo requests, again appearing as the second host.															

Step 4: Port & service discovery

Scan the metasploitable vm for ports:

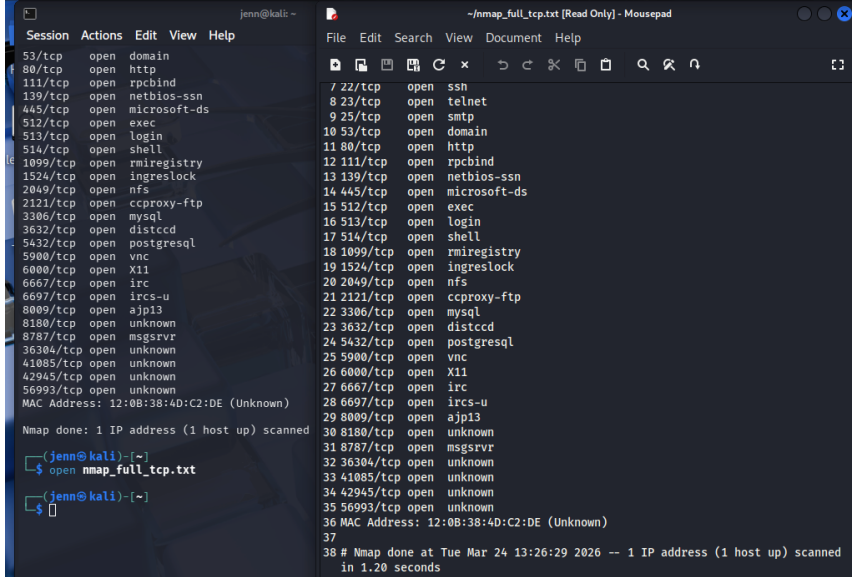
```
(jenn@kali)-[~]
$ sudo nmap -sS -p- -T4 192.168.64.2 -oN nmap_full_tcp.txt
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-24 13:26 PDT
Nmap scan report for 192.168.64.2
Host is up (0.0014s latency).
Not shown: 65505 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
3632/tcp  open  distccd
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
6697/tcp  open  ircs-u
8009/tcp  open  ajp13
8180/tcp  open  unknown
8787/tcp  open  msgsrvr
36304/tcp open  unknown
41085/tcp open  unknown
42945/tcp open  unknown
56993/tcp open  unknown
MAC Address: 12:0B:38:4D:C2:DE (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 1.20 seconds

(jenn@kali)-[~]
```

Nmap scan results showing open ports on Metasploitable (FTP, SSH, Telnet, SMTP, DNS, HTTP, SMB, etc.).

Step 5: Review full text



```
(jenn@kali)-[~]
$ open nmap_full_tcp.txt
(jenn@kali)-[~]
$
```

```
Session Actions Edit View Help
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
3632/tcp  open  distccd
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
6697/tcp  open  ircs-u
8009/tcp  open  ajp13
8180/tcp  open  unknown
8787/tcp  open  msgsrvr
36304/tcp open  unknown
41085/tcp open  unknown
42945/tcp open  unknown
56993/tcp open  unknown
MAC Address: 12:0B:38:4D:C2:DE (Unknown)

Nmap done: 1 IP address (1 host up) scanned

(jenn@kali)-[~]
$ open nmap_full_tcp.txt
(jenn@kali)-[~]
$
```

```
File Edit Search View Document Help
7 22/tcp    open  ssn
8 23/tcp    open  telnet
9 25/tcp    open  smtp
10 53/tcp    open  domain
11 80/tcp    open  http
12 111/tcp   open  rpcbind
13 139/tcp   open  netbios-ssn
14 445/tcp   open  microsoft-ds
15 512/tcp   open  exec
16 513/tcp   open  login
17 514/tcp   open  shell
18 1099/tcp  open  rmiregistry
19 1524/tcp  open  ingreslock
20 2049/tcp  open  nfs
21 2121/tcp  open  ccproxy-ftp
22 3306/tcp  open  mysql
23 3632/tcp  open  distccd
24 5432/tcp  open  postgresql
25 5900/tcp  open  vnc
26 6000/tcp  open  X11
27 6667/tcp  open  irc
28 6697/tcp  open  ircs-u
29 8009/tcp  open  ajp13
30 8180/tcp  open  unknown
31 8787/tcp  open  msgsrvr
32 36304/tcp open  unknown
33 41085/tcp open  unknown
34 42945/tcp open  unknown
35 56993/tcp open  unknown
36 MAC Address: 12:0B:38:4D:C2:DE (Unknown)
37
38 # Nmap done at Tue Mar 24 13:26:29 2026 -- 1 IP address (1 host up) scanned
  in 1.20 seconds
```

Full verbose Nmap output including service banners, OS fingerprinting, and host details.

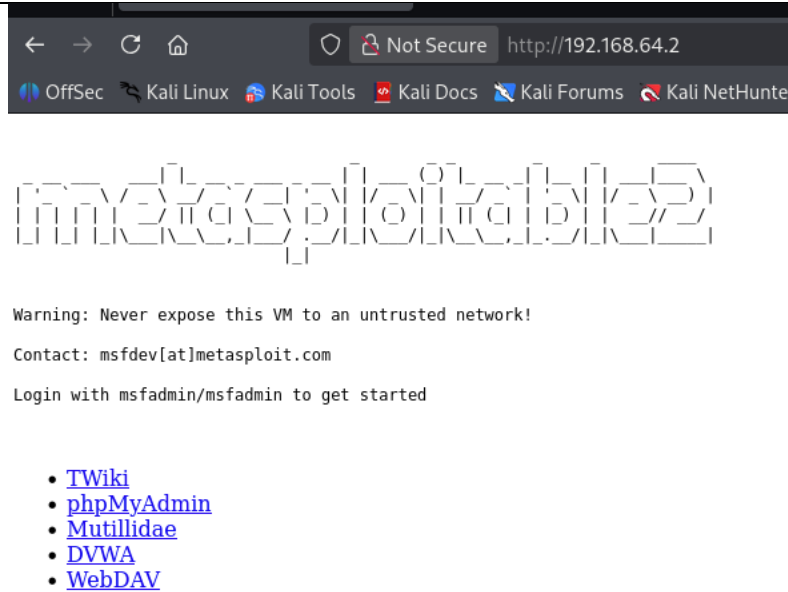
Step 6: Review Scripts & Versions

```
~/nmap_svcs.txt [Read Only] - Mousepad
File Edit Search View Document Help

1 # Nmap 7.95 scan initiated Tue Mar 24 13:31:56 2026 as: /usr/lib/nmap/nmap
  -sC -sV -p21,22,80,139,445,3306 -oN nmap_svcs.txt 192.168.64.2
2 Nmap scan report for 192.168.64.2
3 Host is up (0.00089s latency).
4
5 PORT      STATE SERVICE      VERSION
6 21/tcp    open  ftp          vsftpd 2.3.4
7 | ftp-syst:
8 |   STAT:
9 | FTP server status:
10 |   Connected to 192.168.64.4
11 |   Logged in as ftp
12 |   TYPE: ASCII
13 |   No session bandwidth limit
14 |   Session timeout in seconds is 300
15 |   Control connection is plain text
16 |   Data connections will be plain text
17 |   vsFTPd 2.3.4 - secure, fast, stable
18 |_ End of status
19 |_ftp-anon: Anonymous FTP login allowed (FTP code 230)
20 22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
21 | ssh-hostkey:
22 |   1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
23 |_  2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
24 80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
25 |_http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
26 |_http-title: Metasploitable2 - Linux
27 139/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
28 445/tcp   open  netbios-ssn Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
29 3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
30 | mysql-info:
31 |   Protocol: 10
32 |_  Version: 5.0.51a-3ubuntu5
33 | Thread ID: 8
34 | Thread ID: 8
35 | Capabilities flags: 43564
36 |   Some Capabilities: ConnectWithDatabase, LongColumnFlag, Support41Auth,
37 |   SupportsTransactions, Speaks41ProtocolNew, SwitchToSSLAfterHandshake,
38 |   SupportsCompression
39 | Status: Autocommit
40 |_ Salt: #OHZm6bkqw$Fu;fnw.y9
41 MAC Address: 12:0B:38:4D:C2:DE (Unknown)
42 Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel
43
44 Host script results:
45 |_clock-skew: mean: 2h00m01s, deviation: 2h49m43s, median: 0s
46 |_smb2-time: Protocol negotiation failed (SMB2)
47 | smb-os-discovery:
48 |   OS: Unix (Samba 3.0.20-Debian)
49 |   Computer name: metasploitable
50 |   NetBIOS computer name:
51 |   Domain name: localdomain
52 |   FQDN: metasploitable.localdomain
53 |_ System time: 2026-03-24T16:32:09-04:00
54 | smb-security-mode:
55 |   account_used: guest
56 |   authentication_level: user
57 |   challenge_response: supported
58 |_ message_signing: disabled (dangerous, but default)
59 |_nbstat: NetBIOS name: METASPLOITABLE, NetBIOS user: <unknown>, NetBIOS
60 |   MAC: <unknown> (unknown)
61
62 Service detection performed. Please report any incorrect results at https://
63 nmap.org/submit/ .
64 # Nmap done at Tue Mar 24 13:32:09 2026 -- 1 IP address (1 host up) scanned
65 in 12.80 seconds
66
```

NSE script results showing service versions (e.g., Samba 3.0.20, Apache 2.2.8, vsftpd 2.3.4), confirming vulnerable versions.

Step 7: Part 4 – Web Enumeration – viewing port 80 via http (non-secure) on the Kali web browser:



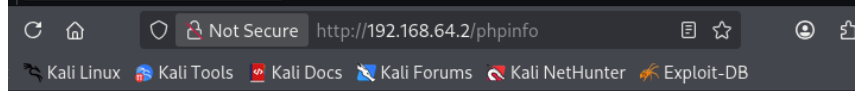
Browser screenshot of Metasploitable's default web page served over HTTP.

Step 8: using gobuster to brute force the server and look up common folder names – php info is open

```
jenn@kali: ~  
Session Actions Edit View Help  
jenn@kali)-[~]  
$ gobuster dir -u http://192.168.64.2/ -w /usr/share/wordlists/dirb/common.txt -t 20 -o gobuster.txt  
Gobuster v3.8  
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)  
[+] Url: http://192.168.64.2/  
[+] Method: GET  
[+] Threads: 20  
[+] Wordlist: /usr/share/wordlists/dirb/common.txt  
[+] Negative Status codes: 404  
[+] User Agent: gobuster/3.8  
[+] Timeout: 10s  
Starting gobuster in directory enumeration mode  
/.htaccess (Status: 403) [Size: 294]  
/.hta (Status: 403) [Size: 289]  
/cgi-bin/ (Status: 403) [Size: 293]  
/dav (Status: 301) [Size: 315] [→ http://192.168.64.2/dav/]  
/index.php (Status: 200) [Size: 891]  
/index (Status: 200) [Size: 891]  
/phpMyAdmin (Status: 301) [Size: 322] [→ http://192.168.64.2/phpMyAdmin/]  
/server-status (Status: 403) [Size: 298]  
/phpinfo (Status: 200) [Size: 47978]  
/phpinfo.php (Status: 200) [Size: 47990]  
/test (Status: 301) [Size: 316] [→ http://192.168.64.2/test/]  
/twiki (Status: 301) [Size: 317] [→ http://192.168.64.2/twiki/]  
Progress: 4613 / 4613 (100.00%)  
Finished
```

Terminal output of gobuster dir showing discovered directories including /phpinfo.php.

Step 9: visit phpinfo in the web browser:



PHP Version 5.2.4-2ubuntu5.10



System	Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686
Build Date	Jan 6 2010 21:50:12
Server API	CGI/FastCGI
Virtual Directory Support	disabled
Configuration File (php.ini) Path	/etc/php5/cgi
Loaded Configuration File	/etc/php5/cgi/php.ini
Scan this dir for additional .ini files	/etc/php5/cgi/conf.d
additional .ini files parsed	/etc/php5/cgi/conf.d/gd.ini, /etc/php5/cgi/conf.d/mysql.ini, /etc/php5/cgi/conf.d/mysqli.ini, /etc/php5/cgi/conf.d/pdo.ini, /etc/php5/cgi/conf.d/pdo_mysql.ini
PHP API	20041225
PHP Extension	20060613
Zend Extension	220060519
Debug Build	no
Thread Safety	disabled
Zend Memory Manager	enabled
IPv6 Support	enabled
Registered PHP Streams	zip, php, file, data, http, ftp, compress.bzip2, compress.zlib, https, ftps
Registered Stream	tcp, udp, unix, udg, ssl, sslv3, sslv3_tls, sslv3_tls

Browser screenshot of the PHP info page, confirming PHP version and configuration exposure.

Step 10: Part 5 -
SMB/FTP/SSH/RPC
Enumeration

enum4linux output showing null-session access, workgroup name, NetBIOS info, and accessible shares including /tmp.

```
(jenn@kali)-[~]
$ enum4linux -a 192.168.64.2 | tee enum4linux.txt
Starting enum4linux v0.9.1 ( http://labs.portcullis.co.uk/application/enum4linux/ ) on Tue Mar 24 14:34:03 2026

===== ( Target Information ) =====
Target ..... 192.168.64.2
RID Range ..... 500-550,1000-1050
Username ..... ''
Password ..... ''
Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none

===== ( Enumerating Workgroup/Domain on 192.168.64.2 ) =====
[+] Got domain/workgroup name: WORKGROUP

===== ( Nbtstat Information for 192.168.64.2 ) =====
Looking up status of 192.168.64.2
METASPLOITABLE <00> - B <ACTIVE> Workstation Service
METASPLOITABLE <03> - B <ACTIVE> Messenger Service
METASPLOITABLE <20> - B <ACTIVE> File Server Service
.._MSBROWSE_ <01> - <GROUP> B <ACTIVE> Master Browser
WORKGROUP <00> - <GROUP> B <ACTIVE> Domain/Workgroup Name
WORKGROUP <1d> - B <ACTIVE> Master Browser
WORKGROUP <1e> - <GROUP> B <ACTIVE> Browser Service Elections

MAC Address = 00-00-00-00-00-00

===== ( Session Check on 192.168.64.2 ) =====
[+] Server 192.168.64.2 allows sessions using username '', password ''
```

Note – was able to get into session without username or password.

```
[+] Attempting to map shares on 192.168.64.2
//192.168.64.2/print$ Mapping: DENIED Listing: N/A Writing: N/A
//192.168.64.2/tmp Mapping: OK Listing: OK Writing: N/A
//192.168.64.2/opt Mapping: DENIED Listing: N/A Writing: N/A

[E] Can't understand response:
NT_STATUS_NETWORK_ACCESS_DENIED listing \*
//192.168.64.2/IPC$ Mapping: N/A Listing: N/A Writing: N/A
//192.168.64.2/ADMIN$ Mapping: DENIED Listing: N/A Writing: N/A

===== ( Password Policy Information for 192.168.64.2 ) =====
Password:

Confirm tmp access
```

Step 11: Confirm SMB access without password	<pre>(jenn@kali)-[~] \$ smbclient -L //192.168.64.2 -N Anonymous login successful Sharename Type Comment ----- print\$ Disk Printer Drivers tmp Disk oh noes! opt Disk IPC\$ IPC IPC Service (metasploitable server (Samba 3 .0.20-Debian)) ADMIN\$ IPC IPC Service (metasploitable server (Samba 3 .0.20-Debian)) Reconnecting with SMB1 for workgroup listing. Anonymous login successful Server Comment ----- Workgroup Master WORKGROUP METASPLOITABLE (jenn@kali)-[~] \$</pre>
	smbclient -L //192.168.64.2 -N output showing anonymous login success and listing available shares.
Step 12: Anonymously login and list tmp contents	<pre>(jenn@kali)-[~] \$ smbclient //192.168.64.2/tmp -N Anonymous login successful Try "help" to get a list of possible commands. smb: \> ls . D 0 Tue Mar 24 14:21:02 2026 .. DR 0 Sun May 20 11:36:12 2012 .ICE-unix DH 0 Tue Mar 24 13:10:47 2026 .X11-unix DH 0 Tue Mar 24 13:10:58 2026 .X0-lock HR 11 Tue Mar 24 13:10:58 2026 4774.jsvc_up R 0 Tue Mar 24 13:11:33 2026 7282168 blocks of size 1024. 5435652 blocks available smb: \></pre>
	smbclient //192.168.64.2/tmp -N showing successful connection and directory listing of the world-readable /tmp share.
Step 13: Login with FTP as anonymous/no password, and then list the directory contents:	<pre>(jenn@kali)-[~] \$ ftp 192.168.64.2 Connected to 192.168.64.2. 220 (vsFTPd 2.3.4) Name (192.168.64.2:jenn): anonymous 331 Please specify the password. Password: 230 Login successful. Remote system type is UNIX. Using binary mode to transfer files. ftp> ls 229 Entering Extended Passive Mode (61403). 150 Here comes the directory listing. 226 Directory send OK. ftp></pre>
	FTP session showing successful anonymous login and directory listing of the FTP root.
Step 14: Attempt SSH	<pre>(jenn@kali)-[~] \$ ssh mfsadmin@192.168.64.2 Unable to negotiate with 192.168.64.2 port 22: no matching host key type found. d. Their offer: ssh-rsa,ssh-dss</pre>
	SSH connection attempt using legacy RSA algorithms required by Metasploitable's outdated SSH server.

Step 15: login and create files:

```
(jennn@kali)~$ ssh -o HostKeyAlgorithms=+ssh-rsa -o PubkeyAcceptedAlgorithms=+ssh-rsa msfadmin@192.168.64.2
The authenticity of host '192.168.64.2 (192.168.64.2)' can't be established.
RSA key fingerprint is: SHA256:BQHm5EoHX9GciOLuVscegpXLQ0suPs+E9d/rRJ8B4rk
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.64.2' (RSA) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
msfadmin@192.168.64.2's password:
Permission denied, please try again.
msfadmin@192.168.64.2's password:
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
Last login: Tue Mar 24 16:11:36 2026
msfadmin@metasploitable:~$ touch newfile.txt
msfadmin@metasploitable:~$ touch newfile.txt
msfadmin@metasploitable:~$ ls -lah
total 44K
drwxr-xr-x 7 msfadmin msfadmin 4.0K 2026-03-24 17:26 .
drwxr-xr-x 6 root root 4.0K 2010-04-16 02:16 ..
lrwxrwxrwx 1 root root 9 2012-05-14 00:26 .bash_history -> /dev/null
ll
drwxr-xr-x 4 msfadmin msfadmin 4.0K 2010-04-17 14:11 .distcc
drwx----- 2 msfadmin msfadmin 4.0K 2026-01-23 06:25 .gconf
drwx----- 2 msfadmin msfadmin 4.0K 2026-01-23 06:25 .gconfd
-rw----- 1 root root 4.1K 2012-05-14 02:01 .mysql_history
-rw-r--r-- 1 msfadmin msfadmin 0 2026-03-24 17:26 newfile.txt
-rw-r--r-- 1 msfadmin msfadmin 586 2010-03-16 19:12 .profile
-rwx----- 1 msfadmin msfadmin 4 2012-05-20 14:22 .rhosts
drwx----- 2 msfadmin msfadmin 4.0K 2010-05-17 21:43 .ssh
-rw-r--r-- 1 msfadmin msfadmin 0 2010-05-07 14:38 .sudo_as_admin_successful
l
drwxr-xr-x 6 msfadmin msfadmin 4.0K 2010-04-27 23:44 vulnerable
msfadmin@metasploitable:~$
```

SSH session as msfadmin showing ability to create files, demonstrating full shell access.

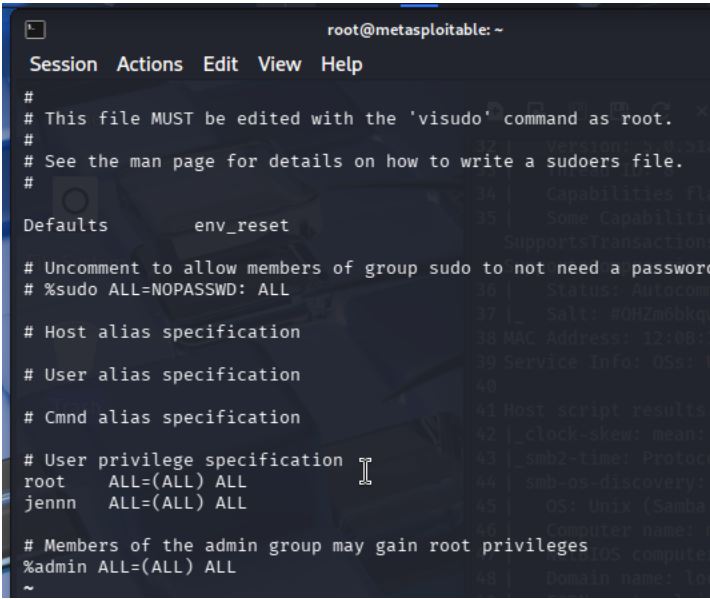
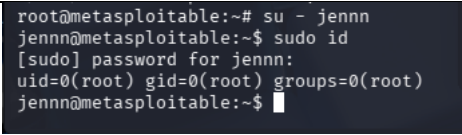
Step 16: Damage would be to create a new user and give it super user permissions

Commands showing creation of user jennn, switching to root, and editing /etc/sudoers via visudo to grant full sudo privileges.

```
msfadmin@metasploitable:~$ sudo useradd -m jennn
msfadmin@metasploitable:~$ sudo passwd jennn
Enter new UNIX password:
Retype new UNIX password:
passwd: password updated successfully
msfadmin@metasploitable:~$ id jennn
uid=1004(jennn) gid=1004(jennn) groups=1004(jennn)
msfadmin@metasploitable:~$ sudo usermod -aG sudo jennn
msfadmin@metasploitable:~$ groups jennn
jennn sudo
msfadmin@metasploitable:~$ su - jenn
Unknown id: jenn
msfadmin@metasploitable:~$ su - jennn
Password:
jennn@metasploitable:~$ sudo id
[sudo] password for jennn:
jennn is not in the sudoers file. This incident will be reported.
jennn@metasploitable:~$
```

Add Jennn to sudoers by switching to root and editing the file:

```
msfadmin@metasploitable:~$ sudo su -
root@metasploitable:~# visudo
```

	
Step 17: confirming newly created user has right privileges:	 Terminal output showing su - jennn followed by sudo id, confirming the user escalates to root (uid=0).

APPENDIX B: Risk Summary

The following table summarizes the major risks identified during the assessment using the Confidentiality, Integrity, and Availability (CIA) triad. This framework provides a structured way to evaluate the security impact of each finding beyond subjective severity ratings.

Finding	Confidentiality Impact	Integrity Impact	Availability Impact
Anonymous SMB Access	Exposes shared files to unauthenticated users; enables data disclosure.	Allows unauthorized file modification or deletion.	Potential for disruption if critical files are altered or removed.
Anonymous FTP Access	Allows retrieval of files without authentication.	Enables unauthorized upload or modification of content.	Could be used to overwrite or remove files, affecting service stability.
Default SSH Credentials	Grants full access to system data.	Enables complete system manipulation, including privilege escalation and configuration changes.	Attacker could disable services or damage system functionality.
Obsolete Telnet Service	Transmits credentials and session data in cleartext, enabling interception.	Intercepted sessions could allow unauthorized command execution.	Compromised sessions could be used to disrupt services.
Obsolete IRC Service	Could expose communication channels or system metadata.	Potential vector for unauthorized command-and-control activity.	IRC-based botnet activity could degrade system performance.
PHP Configuration Exposure (phpinfo)	Reveals detailed system configuration, environment variables, and module information.	Provides attackers with insights to craft targeted exploits.	Minimal direct impact, but increases likelihood of successful attacks.
Outdated Services (General)	Older versions may leak information through known vulnerabilities.	Vulnerabilities could allow unauthorized modification of system state.	Exploits could cause service crashes or instability.
Privilege Escalation via Sudoers Modification	Grants attackers unrestricted access to all system data.	Allows creation of persistent administrative accounts and unauthorized system changes.	Attacker could disable services or lock out legitimate users.

APPENDIX C: Recommendations

Based on the findings of this assessment, several remediation steps are recommended to reduce the system's exposure and prevent similar compromises in a real-world environment. These recommendations are prioritized according to the severity and exploitability of the issues identified.

- 1. Disable Legacy and Obsolete Services** Telnet and IRC should be removed entirely. Both protocols are outdated, insecure, and unnecessary in modern environments. Their continued presence significantly increases the attack surface and exposes the system to credential interception, unauthorized access, and covert communication channels.
- 2. Remove Anonymous Access from SMB and FTP** Anonymous login should be disabled on both SMB and FTP services. Access to shared directories must require authentication, and permissions should be restricted to prevent unauthorized file upload, modification, or exfiltration.
- 3. Enforce Strong Authentication for SSH** Default credentials must be removed immediately. SSH should require unique, strong passwords or key-based authentication. Additionally, the SSH service should be upgraded to a supported version that enforces modern cryptographic standards.
- 4. Restrict Information Disclosure on Web Services** The publicly accessible PHP configuration page should be removed. Exposing detailed system configuration information provides attackers with insights that can be used to tailor exploits and identify additional weaknesses.
- 5. Audit and Harden All Running Services** Several services were running outdated or vulnerable versions. A comprehensive service audit should be performed to identify

unnecessary components, upgrade supported software, and apply security patches.

Services that are not required should be disabled to reduce the overall attack surface.

6. **Strengthen Privileged Access Controls** To prevent unauthorized creation of privileged accounts, the system should implement stronger controls around root-level permissions and administrative actions. Any modification to privileged user configurations—such as changes to the sudoers file or the creation of new administrative accounts—should require strict authentication and be logged and monitored. Regular reviews of privileged accounts and sudo configurations should be performed to detect unauthorized changes. Adopting modern privileged-access-management practices would further reduce the risk of attackers establishing persistent, high-level access.
7. **Implement Privileged Access Monitoring** The ability to create a new privileged user and modify the sudoers file without detection highlights the need for stronger monitoring and auditing of administrative actions. Privileged activity should be logged centrally and reviewed regularly to ensure unauthorized modifications are identified quickly.
8. **Apply Network Segmentation and Access Controls** Where possible, vulnerable or legacy systems should be isolated from production networks. Restricting access to administrative interfaces and sensitive services reduces the likelihood of unauthorized access and lateral movement.